Cyber Security Roadmap: Pentester to AppSec

Learn each topic from Professor Messer, then build it in your own lab

0. Foundations

Weeks 1-2

Learn

- How a URL loads a page
- IP addresses, ports, client and server
- Linux files, folders and permissions
- Users, groups and processes
- Core commands: ls, cd, grep, curl, ping

Practice

- TryHackMe Pre Security path
- Messer A+ Core 1 networking (optional)
- TryHackMe Linux Fundamentals rooms
- OverTheWire Bandit wargame
- Start your GitHub notes repository

1. Networking

Weeks 3-6

Learn: Messer Network+

- OSI and TCP/IP models
- Ports and protocols (HTTP, DNS, SSH, SMB)
- IP addressing, CIDR and subnetting
- DNS records and DHCP process
- Switching, VLANs, routing and NAT
- Firewalls, IDS/IPS and DMZ
- Network attacks: ARP, MITM, DNS poisoning
- Troubleshooting tools and logging

Practice: build in your lab

- Wireshark: label each layer of a packet
- Nmap -sV against Metasploitable
- 10 subnetting drills every day
- dig each record type; capture DHCP
- Linux VM as a router between two subnets
- ufw rules; Suricata alert from a scan
- ARP spoof between your own VMs only
- Break and fix your lab network

2. Security Fundamentals

Weeks 7-10

Learn: Messer Security+

- Threat actors and social engineering
- Malware types and behaviour
- Application attacks overview
- Password attacks and hashing
- Cryptography, PKI and TLS
- Identity, MFA and access control
- Vulnerability scanning, CVE and CVSS
- Incident response and logging
- Python, Bash and Git basics

Practice: build in your lab

- Read phishing email headers
- Read 2 malware analysis reports
- Juice Shop: first SQLi and XSS
- Crack your own hashes with John
- openssl: keys, certificates, hashes
- Linux users, groups, SSH key login
- Greenbone scan of Metasploitable
- Log a brute force, write a timeline
- Write a 20-line Python script

3. Core Pentesting

Weeks 11-20

Learn: pentest skills

- Pentest methodology: recon to report
- Nmap scan types and NSE scripts
- Web and service enumeration
- Password attacks on services
- Exploitation with Metasploit
- Reverse shells and Netcat
- Linux privilege escalation
- Burp Suite basics
- Notes and one-page reports

Practice: labs and platforms

- TryHackMe Jr Penetration Tester path
- Scan Metasploitable, save output
- Gobuster, Nikto, enum4linux in your lab
- Hydra against your own VMs
- VulnHub and Hack The Box easy boxes
- Catch and stabilise a shell
- TryHackMe Linux PrivEsc room
- Proxy Juice Shop through Burp
- 10 write-ups on GitHub

4. Windows and Active Directory

Weeks 21-28

Learn: Windows and AD

- Windows users, services, registry
- PowerShell and event logs
- Active Directory concepts
- Kerberos and common AD attacks
- Windows privilege escalation
- Professional pentest reporting

Practice: labs and reports

- TryHackMe Windows Fundamentals
- Read logs after your own attack
- Build a two-VM AD lab
- TryHackMe AD rooms; your AD lab
- Hack The Box easy Windows boxes
- Write 2 full pentest reports

5. Level Up to AppSec

Months 7-12

Learn: web and AppSec

- HTTP, cookies, sessions and APIs
- SQL injection
- XSS: reflected, stored, DOM
- Access control, IDOR, broken auth
- CSRF, SSRF, file upload, XXE
- API security and JWT
- Secure code review
- Threat modelling and secure SDLC
- JavaScript and a backend language

Practice: PortSwigger and code

- PortSwigger Academy: first labs
- PortSwigger SQL injection labs
- PortSwigger XSS labs
- PortSwigger access control labs
- PortSwigger labs for each topic
- OWASP crAPI; PortSwigger API labs
- Run Semgrep on a small open-source app
- Threat-model Juice Shop with STRIDE
- Build a small Flask app, then attack it

6. Portfolio and Certifications

Ongoing

Certifications

- Security+ after Phase 2
- eJPT or PNPT after Phase 4
- BSCP after Phase 5
- OSCP: optional, much later
- Network+ exam: only if a job asks

Portfolio and jobs

- GitHub write-up for every lab
- 2-3 full pentest reports
- AppSec write-ups with fixes
- TryHackMe and Hack The Box profiles
- Apply: junior pentester or AppSec

7. Mobile App Pentesting

About 6-8 weeks

Learn: topic and resource

- Android basics and APK structure (Android developer docs)
- Testing standard: OWASP MASVS and MASTG (free)
- Static analysis: jadx, apktool, MobSF
- Dynamic analysis: Frida and Objection
- Intercept app traffic with Burp (PortSwigger docs)
- Reading Java and Kotlin code (Kotlin docs, basics)

Practice: where to build it

- Set up an Android emulator and adb lab
- DIVA: Damn Insecure and Vulnerable App
- InsecureBankv2 walkthrough
- OWASP UnCrackable Android apps
- Scan a test app with MobSF and write up findings
- Proxy your own test app through Burp

8. C and Assembly

About 6 weeks

Learn: topic and resource

- C basics: pointers and memory (CS50, Beej's Guide to C)
- x86-64 assembly (OpenSecurityTraining2 Arch1001)
- Stack, heap, calling conventions (LiveOverflow videos)
- PE and ELF file formats (Practical Malware Analysis book)
- Debugging with gdb and x64dbg (tool docs)
- Ghidra basics (official Ghidra docs)

Practice: where to build it

- Write small C programs and step through in gdb
- crackmes.one: easy crackmes
- picoCTF reverse engineering challenges
- pwn.college assembly modules
- TryHackMe reverse engineering rooms
- Solve 5 crackmes in Ghidra and write them up

9. Malware Analysis

Reverse engineering, about 8 weeks

Learn: topic and resource

- Static analysis workflow (Malware Unicorn RE101)
- Dynamic analysis in a sandbox (Malware Unicorn RE102)
- Windows API calls malware uses (Practical Malware Analysis)
- Packers and obfuscation basics
- Safe lab: FlareVM and REMnux, no internet
- Writing malware analysis reports

Practice: where to build it

- Build the isolated malware analysis VM lab
- MalwareBazaar samples, opened in the sandbox only
- Malware Unicorn workshop labs
- Past Flare-On challenges
- Malware-Traffic-Analysis.net exercises
- One report per sample on GitHub

10. Exploit Development

About 8-10 weeks

Learn: topic and resource

- Stack buffer overflows (LiveOverflow, exploit.education)
- Return-oriented programming (ROP Emporium)
- Format strings and heap basics (Nightmare by guyinatuxedo)
- Mitigations: ASLR, DEP, stack canaries
- Fuzzing basics with AFL++

Practice: where to build it

- exploit.education Phoenix
- ROP Emporium challenges
- pwn.college binary exploitation
- Hack The Box pwn challenges
- Reproduce one public CVE in your own VM

11. OSINT and Scam Tracing

Run in parallel from Phase 2

Learn: topic and resource

- OSINT method, ethics and law (Bellingcat guides)
- Domains, WHOIS, DNS, certificates (crt.sh, URLScan)
- Scam site and phishing infrastructure (VirusTotal, Shodan)
- Email headers and sender tracing
- Public usernames and social media (OSINT Framework)
- Crypto wallet tracing (Etherscan, Chainabuse)
- Courses: TCM OSINT Fundamentals, Inteltechniques

Practice: where to build it

- Trace Labs ethical OSINT CTF (missing persons)
- TryHackMe OSINT rooms (Sakura)
- Gralhix OSINT challenges
- Bellingcat Online Investigation Toolkit
- Map a known scam site using public data only
- Report scam numbers and sites to your carrier and the EFCC
- Write one sourced case report

12. Digital Forensics (DFIR)

About 8 weeks, after Phase 4

Learn: topic and resource

- Forensics basics and chain of custody (SANS free posters)
- Disk forensics with Autopsy
- Memory forensics with Volatility
- Windows event logs and artefacts (13Cubed videos)
- Building incident timelines
- Mobile forensics: how examiners work with legal authority

Practice: where to build it

- CyberDefenders blue team labs
- Blue Team Labs Online
- TryHackMe DFIR rooms
- Public disk and memory images (Digital Corpora)
- Investigate your own lab attack from the logs
- Write an incident report with a timeline

13. Red Team and Career

Ongoing

Learn: frameworks and certs

- MITRE ATT&CK framework (free, attack.mitre.org)
- Adversary emulation: Atomic Red Team, Caldera
- Cloud security basics: AWS IAM and misconfigurations
- OSCP for pentesting, then OSEP or OSWE
- GREM for malware or OSED for exploit dev, later
- GCFA or GCFE for forensics, later

Practice: portfolio and jobs

- GitHub write-ups for every branch
- Join CTF teams through CTFtime
- Bug bounty on HackerOne or Bugcrowd, in scope only
- Keep one public project per specialty
- Apply: pentester, malware analyst, DFIR, fraud investigator
- Trace Labs and OSINT case reports